

조직 지원 및 사내 정치

취약점 관리는 기술적 문제만이 아닙니다. 분석 결과를 실질적인 보안 개선으로 연결하려면 **사람 간의 상호작용**과 조직 구조, 정치적 역학에 대한 깊은 이해가 필수적입니다.

CHAPTER 6



상충하는 우선순위의 균형 맞추기

보안 분석가는 혼자 모든 문제를 해결할 수 없습니다. 서로 다른 우선순위를 가진 부서와 협력해야 합니다.

보안 분석가

취약점 해결 및 보안 태세 강화

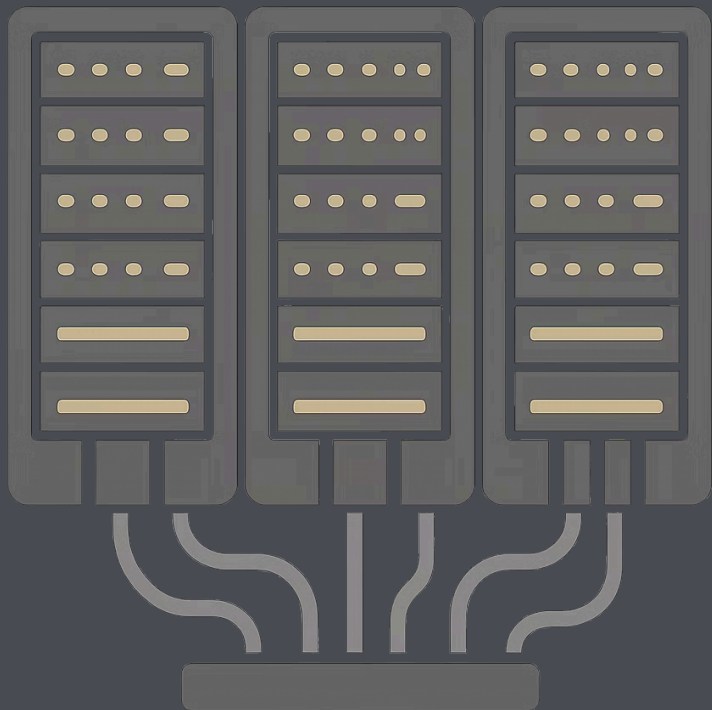
시스템/DB 관리자

시스템 가동 시간 유지 및 안정적 운영

애플리케이션 소유자

프로그램의 정상 작동 확인

거시적으로는 목표가 일치하지만, 현장에서는 이러한 우선순위들이 충돌할 수 있습니다. 어느 쪽도 틀리지 않았습니니다. 다만 실질적인 전략이 서로 부딪히는 것입니다.



실제 사례: 데이터베이스 서버의 취약점

Windows 커널에 원격 인증 없이 악용 가능한 취약점이 발견된 경우를 가정해 보겠습니다. 해당 서버는 조직 운영에 필수적인 데이터베이스 서버입니다.

조직 구조 파악

세 담당자가 같은 관리자를 공유한다면, 먼저 관리자와 이야기해야 합니다.

정치적 상황 고려

임원과 직접 소통하는 것은 부적절할 수 있습니다. 직속 상사를 통해 보고하는 것이 우선입니다.

공식 정책 확인

명확한 보안 정책이 있다면 준수하면 됩니다. 없다면 정책 수립을 고려해야 합니다.

지지 확보를 위한 5가지 전략



공감

상대방의 입장에서 그들이 무엇을 원하는지 이해하세요.



이해관계자 조기 참여

프로세스 초기 단계부터 관련자들을 참여시키세요.



사내 정치 이해

누구에게 어떻게 접근해야 하는지 파악하세요.



그들의 언어로 말하기

기술자에겐 기술 용어, 비즈니스 담당자에겐 ROI로 소통하세요.



챔피언 찾기

보안에 관심 있는 고위 임원의 지지를 확보하세요.

공감: 상대방의 관점 이해하기

Windows 관리자에게

패치로 인한 다운타임은 **통제 가능하고 계획적**으로 수행할 수 있습니다. 반면, 패치하지 않으면 예기치 않은 장기 다운타임이 발생할 수 있습니다.

DBA 및 애플리케이션 소유자에게

취약점이 악용되면 **데이터 조작, 파괴, 유출**로 이어질 수 있습니다. 데이터 보호를 위해 계획된 다운타임을 감수할 가치가 있습니다.

상대방을 이해하려는 의지만으로도 큰 마찰을 피하고, 보안 강화의 새로운 아군을 얻을 수 있습니다.

사내 정치와 언어의 힘

사내 정치를 이해하라

누가 임원진에게 영향력이 있는지 파악하면 논란이 될 조치에 대한 승인을 얻는 데 유리합니다. 단기 성공이 장기적 관계를 해칠 수 있음을 명심하세요.

그들의 언어로 말하라

기술 담당자에게는 가동 시간·패치 수준 등 기술 용어를, 비즈니스 담당자에게는 **ROI**나 **위험/통제** 용어를 사용하세요. 상대의 언어로 말하면 신뢰를 얻을 수 있습니다.

챔피언을 찾아라

CIO, CTO, CFO 등 고위 임원의 지지를 확보하되, 그 특권을 남용하지 마세요. CISO가 있다면 조직 고위층에서 보안 문제를 효과적으로 전달할 수 있습니다.



위험 관리: 핵심 공식

$$\text{위험} = \text{발생 가능성} \times \text{비용}$$

취약점 해결을 설득할 때 이 공식을 활용하세요. 부정적 사건의 위험을 평가하려면 두 가지를 고려해야 합니다.

발생 가능성

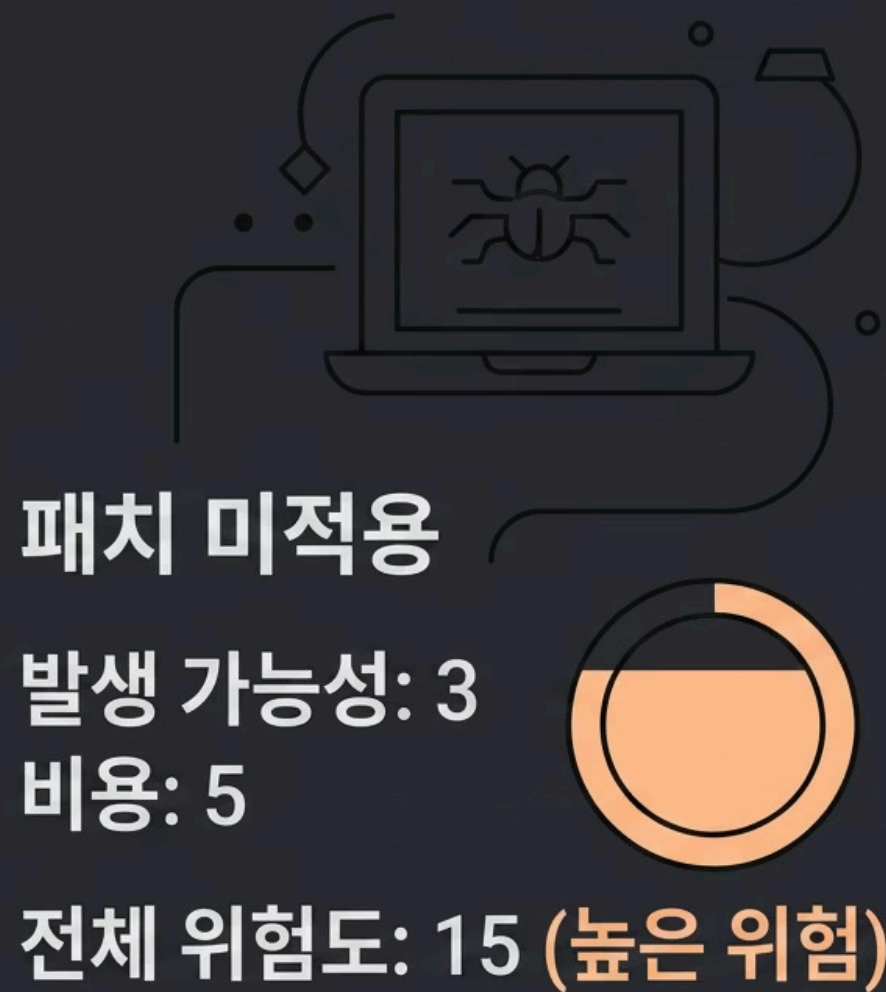
해당 사건이 실제로 일어날 확률은 얼마나 되는가?

비용

사건 발생 시 조직에 미치는 재정적·운영적 피해는 얼마나 되는가?

구체적인 수치 없이도 위험 매트릭스를 활용해 1~5 척도로 발생 가능성과 비용을 순위화하고, 두 축을 결합해 전반적인 위험 수준(낮음~높음)을 결정할 수 있습니다.

위험 매트릭스 실전 적용: 패치 vs. 미패치



패치를 적용하지 않을 경우 전체 위험도는 **15**로, 패치 적용 시 위험도 **6**보다 훨씬 높습니다. 데이터 유출 시 경쟁 우위 손실과 심각한 부정적 여론까지 감수해야 합니다. 조치를 취하는 것이 합리적인 선택입니다.

위험 계산의 추가 활용 사례



보안 투자 비용 대비 효과

도구 가격이 \$150,000인데 완화하는 위험의 해결 비용이 \$10,000에 불과하다면, 그것은 좋은 투자가 아닙니다. 위험 계산으로 투자 타당성을 검증하세요.



공격자 유형별 대응 전략

기회주의적 범죄자라면 단순한 방어에 집중하는 것이 비용 효율적입니다. 고도화된 블랙햇 해커라면 더 정교하고 비용이 많이 드는 대응책이 필요합니다.

요약: 기술을 넘어 사람을 움직이는 보안

관계 구축

조직 내 신뢰 관계를 쌓으면 보안 조치 시행이 훨씬 수월해집니다.

강력한 근거 제시

위험 관리 개념을 활용해 패치·완화 조치의 필요성을 설득력 있게 주장하세요.

경영진 지원 확보

IT 위험 관리 프로그램에 대한 경영진의 지지는 장기적으로 가장 강력한 자산입니다.

- ✔ 보안 담당자는 공식적 권한은 적지만, 공감·소통·위험 관리 전략으로 조직 전체의 보안 태세를 실질적으로 강화할 수 있습니다.

